Conformité, EU AI Act et équité

Le jeu chargé est synthétique. Aucune personne réelle n'est enregistrée. L'analyse décrit le système tel qu'il serait exploité sur de vraies factures, parce que le cahier le classe parmi les systèmes à risque élevé.

Les pièces déjà tenues dans le dépôt : `docs/02-conformite/registre-traitements.md`, `docs/02-conformite/aipd.md`, `docs/02-conformite/note-pseudonymisation.md`, `docs/02-conformite/procedure-droits.md`.

Rapport RGPD

Rubrique	Tenue du projet
Finalité	Repérer une facture suspecte, l'expliquer, laisser un gestionnaire décider
Base, si les données devenaient réelles	Intérêt légitime de l'organisme et obligation de lutte contre la fraude, avec analyse d'impact. Le projet lui-même n'a pas de base légale à exercer : les lignes sont fabriquées
Responsable	L'organisme qui exploiterait la pile. Ici, l'équipe capstone
Catégories	Identité (coffre chiffré), couverture, soins facturés, score
Personnes	Assurés, prestataires, gestionnaires, administrateur
Destinataires	Gestionnaire (facture et score), assistant (historique de l'assuré connecté), administrateur (ré-identification)
Transferts	La pile Docker reste locale. L'appel au modèle de langage pour un PDF ou une question sort vers l'API configurée dans `LLM_BASE_URL`. Le message d'alerte et la question ne doivent pas porter de nom, de téléphone, d'e-mail ni de CIN
Durée	Identités : `retention_identites_years`, valeur initiale 5 ans. Audit : 1 an
Droits	Ré-identification et effacement par l'administrateur, avec la clef d'administration. L'acte est écrit dans `app.audit_log` sans le nom

Mesures : coffre chiffré, pseudonyme HMAC, rôle applicatif qui ne lit pas le coffre, agent sans les schémas `identites`, `raw` et `labels`, scan au chargement qui échoue si un e-mail, un téléphone, un CIN ou un nom complet apparaît dans `clean`.

Risque résiduel : `raw` garde la copie des fichiers sources, y compris le nom du souscripteur. Ce schéma n'est pas servi à l'API ni à l'assistant. La ville et le sexe restent dans `clean` comme quasi-identifiants. Ils ne font pas partie des 23 variables du score.

Grille EU AI Act

Le cahier demande le cadrage d'un système à risque élevé : un score peut conduire à un contrôle de facture et à un refus de remboursement. La revue humaine réduit le risque. Elle ne sort pas le système du cadrage.

Exigence	État	Preuve
Gestion du risque	Analyse d'impact rédigée. Le score ne rejette pas seul	`docs/02-conformite/aipd.md`, décision humaine dans Alertes
Gouvernance des données	Jeu synthétique, labels séparés du schéma servi, colonnes interdites au chargement du modèle	`COLONNES_INTERDITES`, schéma `labels` hors de l'API
Traçabilité	Version du modèle enregistrée avec le score. Décision, changement de seuil et ré-identification audités	`app.predictions`, `app.audit_log`
Transparence	L'alerte porte le score, le seuil, la version et les contributions SHAP	rapport montré au gestionnaire
Contrôle humain	Valider, rejeter, ou demander un complément. Trois issues, pas une décision automatique	file des alertes
Exactitude et robustesse	Fiche de test : rappel `v2` 0,947 sur 12 689 factures. Facture invalide rejetée avec un code, sans erreur 500. Dérive prévue par PSI	`models/v2/metadata.json`, validation, Supervision
Cybersécurité	Voir la spécification de sécurité	06-specification-securite.md
Surveillance après mise en service	Volume, latence, erreurs, PSI	écran Supervision

Point ouvert : `distribution_reference` n'est pas dans les fiches `v1` et `v2`. Le calcul de dérive répond, et l'état reste `reference_absente` tant que ces quatre parts ne sont pas déposées. Le système est donc supervisé sur le volume et les erreurs, pas encore sur un écart de distribution chiffré.

Audit d'équité

Ce qui a été vérifié

Les 23 variables de `v1` et de `v2` sont des signaux de facture et d'ordonnance : péremption, quantités, hors convention, ratios de tarif, répétition, fenêtres de 7 jours, délai, majoration, upcoding, jour de fermeture, type de facture. Ni le nom, ni le sexe, ni la tranche d'âge, ni la ville, ni le CIN ne sont des entrées du score.

Le partage d'évaluation est temporel, pas un tirage aléatoire. Le déséquilibre de classe est traité par `scale_pos_weight` (10,4), pas par une copie synthétique des lignes minoritaires dans le fichier servi.

Ce qui n'a pas été mesuré

Aucun taux d'alerte ni aucun rappel par sexe, par tranche d'âge ou par ville n'est calculé dans le dépôt. Inventer ces taux serait une fausse audit. L'absence d'un attribut dans les variables n'empêche pas un écart indirect : la spécialité, le montant ou l'établissement peuvent suivre une répartition démographique.

Contrôle à faire avant des données réelles

Sur le jeu de test déjà labellisé, calculer le taux d'alerte et le rappel par tranche d'âge et par sexe, sans ajouter ces colonnes au modèle. Un écart important se traite par le seuil ou par une variable proxy, puis se remesure. Ce contrôle n'est pas une condition du démarrage de la démonstration synthétique. Il le devient dès qu'une facture réelle est scorée.